Exposia

Révéler ce qui vous expose

RAPPORT D'ANALYSE

De la menace à l'action : comprendre votre exposition et prioriser les mesures.

THREAT — ASSETS — RISKS — MITIGATIONS

ORGANISATION	Exemple
DOMAINE ANALYSÉ	exemple.com
DATE D'ANALYSE	18 octobre 2026
NIVEAU DE CRITICITÉ	ÉLEVÉ

CONFIDENTIEL — USAGE INTERNE UNIQUEMENT

AVANT-PROPOS

Ce que ce rapport dit — et ce qu'il ne dit pas

Ce rapport décrit votre exposition **depuis Internet**, du point de vue d'un attaquant externe : **sans accès privilégié, sans jamais toucher à vos systèmes**. Chaque constat repose sur des sources publiques et reconnues : certificats publiés, DNS, Shodan, base de vulnérabilités du NIST (NVD), probabilités d'exploitation (EPSS) et référentiels d'exploits publics.

CE QU'IL EST

Une photographie, à date, de votre surface d'attaque externe, hiérarchisée selon la gravité technique, la probabilité d'exploitation et l'impact métier. Un outil de décision : il indique où agir en premier.

CE QU'IL N'EST PAS

Un test d'intrusion. Aucune vulnérabilité n'a été exploitée : la plupart sont déduites des versions logicielles annoncées par les services exposés. Un correctif déjà appliqué peut ne pas être détecté si la version annoncée n'a pas changé. Les actifs non publiés et votre réseau interne sont hors champ. Les scénarios d'attaque sont représentatifs, et la sensibilité d'un service est présumée d'après sa nature.

Chaque constat est rattaché à sa source et doit être vérifié par vos équipes avant toute intervention. Les informations présentées sont accessibles publiquement. Leur regroupement permet de mieux comprendre votre exposition et de prioriser les actions.

SOMMAIRE

Votre rapport en cinq temps

Chaque partie s'ouvre sur un encadré « En clair » qui en résume l'essentiel : la synthèse suffit pour décider, les parties suivantes apportent le détail.

SYNTHÈSE

De la menace à la mitigation 4

PARTIE 1 · MENACES

Qui vous attaque, et pourquoi ? 7

PARTIE 2 · ACTIFS

Quel est votre périmètre exposé ? 10

PARTIE 3 · RISQUES

Quels impacts sur votre business ? 13

PARTIE 4 · MITIGATION

Que faire concrètement ? 17

SYNTHÈSE

De la menace à la mitigation

EN CLAIR

Notre analyse révèle **6 profils d'attaque** susceptibles d'exploiter **27 vulnérabilités** sur **27 services** exposés. La priorité est la **mise à jour des logiciels concernés**. En complément, **52 mesures** composent une feuille de route pour réduire durablement l'exposition et concentrer les efforts là où ils créent le plus de valeur.

Méthodologie

Notre démarche croise quatre volets complémentaires pour vous donner une vision claire et hiérarchisée de vos risques :

- **Threat Modeling** — identification des **attaquants les plus crédibles** selon votre profil.
- **Asset Discovery** — cartographie de votre **périmètre exposé** (sous-domaines, services, ports).
- **Risk Assessment** — mise en évidence des **vulnérabilités exploitables** et des **scénarios d'attaque types**.
- **Mitigation Plan** — sélection et classement des **bonnes pratiques** les plus utiles.

Chaque chaîne ci-dessous relie une vulnérabilité prioritaire à un profil d'attaquant dont les motivations sont compatibles avec les impacts envisagés, pour rendre le scénario et la réponse à y apporter plus concrets.

Chaînes de menaces

Scénario 1 CRITIQUE

ACTEUR	ACTIF	VECTEUR	MITIGATION
Crime organisé Lucratif	**test-bastion01.exemple.com** 139.81.X.X:22	**Accès d'administration** CVE-2024-6387	**MIT-VULN-001** Couvre 24 vuln.

Un acteur de type **Crime organisé** (motivation : **lucratif**) cible **test-bastion01.exemple.com** (139.81.X.X:22). En exploitant la vulnérabilité **CVE-2024-6387** sur votre **Accès d'administration**, il compromet totalement le système, accède à toutes les données sensibles et peut interrompre les opérations critiques. La première mesure consiste à **mettre à jour le logiciel concerné** ; la mesure **MIT-VULN-001** (« Établir une procédure de déploiement de correctifs en urgence ») contribue à réduire durablement ce type de risque.

Scénario 2 CRITIQUE

ACTEUR	ACTIF	VECTEUR	MITIGATION
Étatique Influence	**test-bastion01.exemple.com** 139.81.X.X:22	**Accès d'administration** CVE-2023-48795	**MIT-ANON-002** Couvre 11 vuln.

Un acteur de type **Étatique** (motivation : **influence**) cible **test-bastion01.exemple.com** (139.81.X.X:22). En exploitant la vulnérabilité **CVE-2023-48795** sur votre **Accès d'administration**, il modifie des informations critiques sans affecter la confidentialité ou la disponibilité. La première mesure consiste à **mettre à jour le logiciel concerné** ; la mesure **MIT-ANON-002** (« Définir une matrice d'autorisation claire par rôle et service ») contribue à réduire durablement ce type de risque.

Scénario 3 CRITIQUE

ACTEUR	ACTIF	VECTEUR	MITIGATION
Terroriste Entrave au fonctionnement	**test-bastion01.exemple.com** 139.81.X.X:22	**Accès d'administration** CVE-2023-38408	**MIT-COMP-001** Couvre 5 vuln.

Un acteur de type **Terroriste** (motivation : **entrave au fonctionnement**) cible **test-bastion01.exemple.com** (139.81.X.X:22). En exploitant la vulnérabilité **CVE-2023-38408** sur votre **Accès d'administration**, il compromet totalement le système, accède à toutes les données sensibles et peut interrompre les opérations critiques. La première mesure consiste à **mettre à jour le logiciel concerné** ; la mesure **MIT-COMP-001** (« Établir un plan de continuité en cas de compromission majeure ») contribue à réduire durablement ce type de risque.

Focus sur les mesures prioritaires

MIT-EXPLOIT-001
Couvre 14 vulnérabilités

Établir une veille sur les exploits publiés pour les technologies utilisées

MIT-VULN-001
Couvre 24 vulnérabilités

Établir une procédure de déploiement de correctifs en urgence

MIT-ANON-002
Couvre 11 vulnérabilités

Définir une matrice d'autorisation claire par rôle et service

PARTIE 1 · MENACES

Qui vous attaque, et pourquoi ?

EN CLAIR

L'analyse a identifié **6 profils d'attaquants** susceptibles de cibler votre organisation. Aucun n'atteint le niveau critique au regard de votre profil ; le plus pertinent est **Crime organisé**. La motivation la plus représentée est **« Entrave au fonctionnement »**, associée à **38 % des attaques potentielles**.

Méthodologie

Notre approche du **threat modeling** croise le profil de votre organisation — **secteur, taille, zone géographique et niveau d'exposition** — avec les caractéristiques de **huit types d'acteurs malveillants**. Nous analysons leurs motivations — **espionnage, profit, sabotage, influence** — pour compléter l'analyse des menaces en tenant compte de votre profil, puis nous pondérons chaque acteur selon ces mêmes critères afin de le **hiérarchiser par un filtrage probabiliste**. En clair : nous identifions **qui peut vous attaquer, pourquoi et avec quel niveau de pertinence au regard de votre profil**.

Matrice de priorisation des menaces

RANG	ACTEUR	MOTIVATION PRINCIPALE	PROFIL	NIVEAU
1	**Crime organisé**	Lucratif	Double finalité (2)	ÉLEVÉ
2	**Étatique**	Espionnage	Multi-objectifs (4)	ÉLEVÉ
3	**Terroriste**	Entrave au fonctionnement	Double finalité (2)	MODÉRÉ
4	**Officine**	Entrave au fonctionnement	Double finalité (2)	MODÉRÉ
5	**Activiste**	Entrave au fonctionnement	Double finalité (2)	MODÉRÉ
6	**Malveillant**	Défi, amusement	Ciblé (1)	FAIBLE

Profils d'attaquants détaillés

CRIME ORGANISÉ

Profil : Double finalité • 2 motivations actives

Sophistication : Élevée • **Ressources** : Importantes • **Probabilité** : Élevée

TYPOLOGIE

Motivés par le **profit financier**, ces groupes agissent comme des entreprises criminelles, avec des modèles économiques structurés (ransomware-as-a-service, fraude bancaire, vol de données). Ils ciblent souvent les **TPE/PME** en raison de leur vulnérabilité accrue. Leurs attaques sont généralement **opportunistes** mais bien organisées.

MOTIVATIONS IDENTIFIÉES

- **Lucratif**
  Niveau élevé × Ressources importantes × Pertinence très élevée
- **Entrave au fonctionnement**
  Niveau modéré × Ressources significatives × Pertinence modérée

ÉTATIQUE

Profil : Multi-objectifs • 4 motivations actives

Sophistication : Très élevée • **Ressources** : Illimitées • **Probabilité** : Très élevée

TYPOLOGIE

Ces groupes disposent de **ressources illimitées et d'une expertise de pointe**. Ils opèrent sur le long terme avec des objectifs stratégiques : **espionnage économique**, **influence politique**, **positionnement géopolitique**, ou **sabotage d'infrastructures critiques**. Leur approche privilégie la **furtivité** et la **persistance** pour éviter la détection.

MOTIVATIONS IDENTIFIÉES

- **Espionnage**
  Niveau élevé × Ressources illimitées × Pertinence très élevée
- **Influence**
  Niveau élevé × Ressources illimitées × Pertinence très élevée
- **Géopositionnement stratégique**
  Niveau modéré × Ressources significatives × Pertinence modérée
- **Entrave au fonctionnement**
  Niveau modéré × Ressources significatives × Pertinence modérée

TERRORISTE

Profil : Double finalité • 2 motivations actives

Sophistication : Moyenne à élevée • **Ressources** : Importantes • **Probabilité** : Variable

TYPOLOGIE

Utilisation du cyberespace pour compléter leurs actions physiques : **propagande**, **recrutement**, **sabotage symbolique**, ou **attaques psychologiques** (ex: défacement de sites). Leur sophistication technique est variable, mais leur impact médiatique est souvent disproportionné.

MOTIVATIONS IDENTIFIÉES

- **Entrave au fonctionnement**
  Niveau élevé × Ressources importantes × Pertinence très élevée
- **Influence**
  Niveau modéré × Ressources importantes × Pertinence modérée

PARTIE 2 · ACTIFS

Quel est votre périmètre exposé ?

EN CLAIR

Votre périmètre comprend **75 sous-domaines** et **27 services distincts**, répartis en **5 catégories**. Parmi eux, **4 services présumés sensibles** (administration, transfert de fichiers, base de données…) : généralement destinés à un usage interne, ils méritent une vérification de leur accessibilité depuis Internet.

Méthodologie

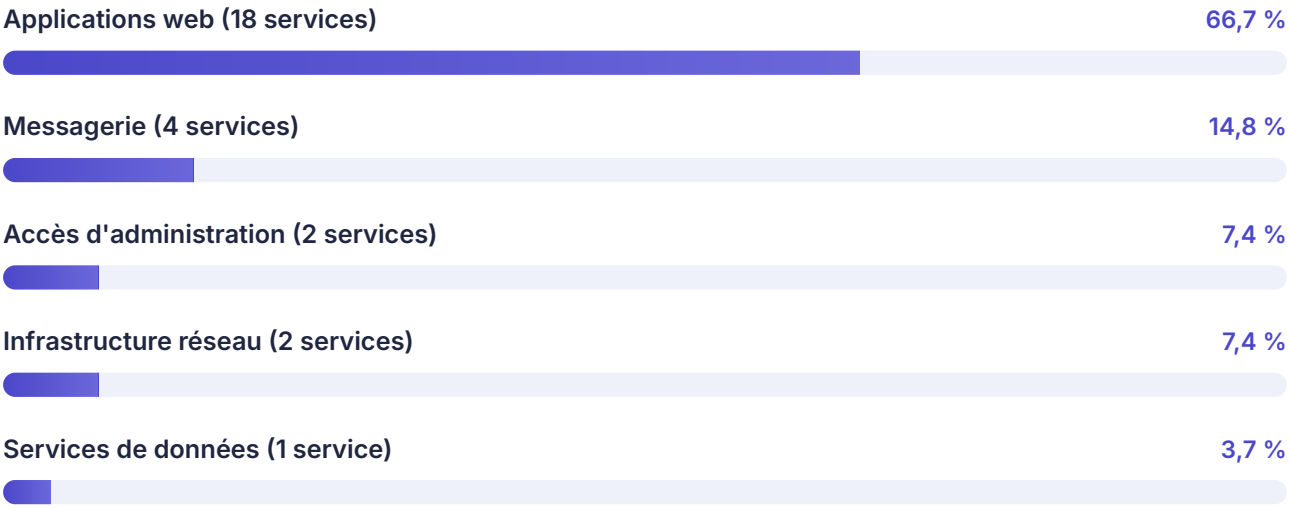
Notre découverte repose exclusivement sur des **méthodes passives et non intrusives**, sans aucun impact sur vos systèmes : analyse des certificats SSL publics, résolution DNS et examen des services exposés à partir de données ouvertes. Chaque service est catégorisé et qualifié selon sa **nature présumée** : **sensible** lorsqu'il s'agit d'un type de service habituellement réservé à un usage interne, **standard** sinon. Son **impact potentiel sur votre activité** est ensuite estimé selon sa criticité et son exposition. En clair : un inventaire **complet et actionnable**, obtenu sans jamais toucher à votre production.

Matrice de découverte des actifs

RANG	SOUS-DOMAINE	SERVICE	CATÉGORIE	NATURE PRÉSUMÉE	IMPACT
1	**test-bastion01.exemple.com**	139.81.X.X:22	Accès d'administration	SENSIBLE	CRITIQUE
2	**test-bastion01.exemple.com**	139.81.X.X:10250	Accès d'administration	SENSIBLE	CRITIQUE
3	**internal-web36.exemple.com**	139.96.X.X:80	Application web	SENSIBLE	HAUTE
4	**internal-web36.exemple.com**	139.96.X.X:443	Application web	SENSIBLE	HAUTE
5	**admin-web09.exemple.com**	139.96.X.X:80	Application web	SENSIBLE	HAUTE
6	**admin-web09.exemple.com**	139.96.X.X:443	Application web	SENSIBLE	HAUTE
7	**dev-web31.exemple.com**	139.96.X.X:80	Application web	SENSIBLE	HAUTE
8	**dev-web31.exemple.com**	139.96.X.X:443	Application web	SENSIBLE	HAUTE
9	**test-web08.exemple.com**	139.96.X.X:80	Application web	SENSIBLE	HAUTE
10	**test-web08.exemple.com**	139.96.X.X:443	Application web	SENSIBLE	HAUTE

Nature présumée : déduite du type de service (port, protocole, nom du sous-domaine). « Sensible » signale un service habituellement réservé à un usage interne, à confirmer avec vos équipes.

Répartition par catégories de services



PARTIE 3 · RISQUES

Quels impacts sur votre business ?

EN CLAIR

Nous avons identifié **27 vulnérabilités** et en avons tiré **36 scénarios d'attaque types distincts** (un même scénario peut concerner plusieurs actifs). Des exploits publics sont référencés pour certaines des vulnérabilités identifiées : **120 exploits** sont recensés. Parmi vos actifs, **test-bastion01.exemple.com** se démarque et nécessite une attention particulière. Les vecteurs d'attaque se concentrent sur les catégories **Accès d'administration** et **Infrastructure réseau**.

Méthodologie

Notre approche combine l'**analyse des impacts opérationnels** avec des **scénarios d'attaque types**, représentatifs des attaques courantes sur vos services exposés et sur les vulnérabilités identifiées. Chaque scénario est évalué selon sa **criticité contextuelle**, intégrant :

- la **criticité technique** (CVSS),
- la **probabilité d'exploitation** (EPSS),
- l'**impact métier** du service concerné (interruption, fuite de données, perte financière, conformité).

En clair : comprendre **comment une menace technique peut affecter votre activité**, selon sa probabilité et son impact potentiel.

Matrice de priorisation des risques

RANG	ACTIF	SERVICE	CRITICITÉ	EXPLOITS	SCÉNARIOS APPLICABLES
1	**test-bastion01.exemple.com**	Accès d'administration (Port 22)	CRITIQUE	120	27
2	**test-bastion01.exemple.com**	Infrastructure réseau (Port 179)	MOYEN	0	0
3	**test-bastion01.exemple.com**	Accès d'administration (Port 10250)	MOYEN	0	1
4	**internal-web36.exemple.com**	Application web (Port 80)	MOYEN	0	1
5	**internal-web36.exemple.com**	Application web (Port 443)	MOYEN	0	1
6	**web30.exemple.com**	Application web (Port 80)	MOYEN	0	1
7	**web30.exemple.com**	Application web (Port 443)	MOYEN	0	1
8	**web38.exemple.com**	Application web (Port 80)	MOYEN	0	1
9	**web38.exemple.com**	Application web (Port 443)	MOYEN	0	1
10	**web02.exemple.com**	Application web (Port 80)	MOYEN	0	1

Scénarios d'attaque types sur vos actifs critiques

Ces scénarios illustrent la manière dont un attaquant pourrait exploiter vos services les plus exposés. Lorsqu'une vulnérabilité précise est en cause, sa référence (CVE) est indiquée ; les autres scénarios décrivent des attaques courantes sur ce type de service.

TEST-BASTION01.EXEMPLE.COM | Service Accès d'administration • 139.81.X.X • Ports 22, 10250 • Critique

Scénario #1 • CVE-2024-6387 • Critique

RECONNAISSANCE

Un attaquant distant recherche les services exposés et peut identifier cette vulnérabilité depuis Internet

EXPLOITATION

Il pourrait exploiter cette vulnérabilité sans authentification, à condition de réunir des circonstances favorables (position d'interception sur le réseau, configuration ou fenêtre de temps particulières)

IMPACT

Il compromet totalement le système, accède à toutes les données sensibles et peut interrompre les opérations critiques

Scénario #2 • CVE-2023-48795 • Critique

RECONNAISSANCE

Un attaquant distant recherche les services exposés et peut identifier cette vulnérabilité depuis Internet

EXPLOITATION

Il pourrait exploiter cette vulnérabilité sans authentification, à condition de réunir des circonstances favorables (position d'interception sur le réseau, configuration ou fenêtre de temps particulières)

IMPACT

Il modifie des informations critiques sans affecter la confidentialité ou la disponibilité

Scénario #3 • CVE-2023-38408 • Critique

RECONNAISSANCE

Un attaquant distant recherche les services exposés et peut identifier cette vulnérabilité depuis Internet

EXPLOITATION

Il pourrait exploiter cette vulnérabilité sans authentification, éventuellement de manière automatisée

IMPACT

Il compromet totalement le système, accède à toutes les données sensibles et peut interrompre les opérations critiques

INTERNAL-WEB36.EXEMPLE.COM / WEB30.EXEMPLE.COM / WEB38.EXEMPLE.COM / WEB02.EXEMPLE.COM

Service Application web • 139.96.X.X • Ports 80, 443 • Moyen

Scénario #1 • Attaque courante sur ce service • Moyen

RECONNAISSANCE

Un attaquant scanne l'application web et identifie des champs de saisie vulnérables aux injections SQL

EXPLOITATION

Il injecte du code SQL malveillant pour contourner l'authentification et accéder à la base de données

IMPACT

Il extrait des données sensibles, modifie des informations ou supprime des enregistrements critiques

Scénario #2 • Attaque courante sur ce service • Moyen

RECONNAISSANCE

Un attaquant scanne l'application web sécurisée et identifie des vulnérabilités applicatives

EXPLOITATION

Il exploite les failles OWASP Top 10 malgré le chiffrement HTTPS

IMPACT

Il compromet les sessions des utilisateurs et accède aux données sensibles de l'application

PARTIE 4 · MITIGATION

Que faire concrètement ?

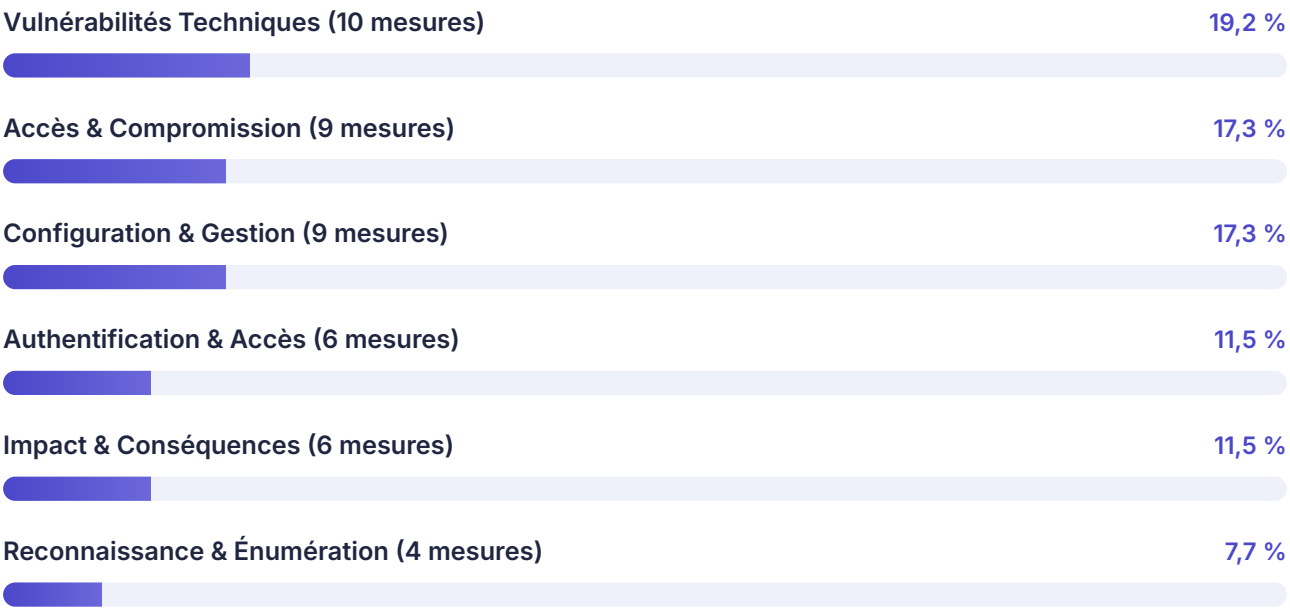
EN CLAIR

Les **27 vulnérabilités** identifiées sont principalement associées à des versions logicielles potentiellement vulnérables : leur traitement passe d'abord par **l'application des mises à jour éditeur**, en commençant par les services les plus exposés.
Les **52 mesures** présentées ci-dessous sont **complémentaires** : ce sont des **bonnes pratiques** qui réduisent durablement votre exposition, indépendamment d'une vulnérabilité particulière. Elles sont majoritairement **préventives (75 %)**, complétées par des mesures **détectives (21 %)** et **curatives (4 %)**. La mesure prioritaire consiste à **établir une veille sur les exploits publiés pour les technologies utilisées** (MIT-EXPLOIT-001).

Méthodologie

Les mesures sont sélectionnées à partir des **scénarios d'attaque** associés à vos services exposés et à vos vulnérabilités, puis **classées par ordre de priorité**. Chaque mesure est classée selon son efficacité estimée, sa couverture de plusieurs types de menaces et sa facilité de mise en œuvre. En clair : une **feuille de route de bonnes pratiques, claire et hiérarchisée**, qui complète la mise à jour de vos logiciels.

Répartition par catégorie



Protocoles & Communications (3 mesures) 5,8 %

Développement & Applications (2 mesures) 3,8 %

Services Spécifiques (1 mesure) 1,9 %

Ingénierie Sociale & Email (1 mesure) 1,9 %

Conteneurisation & Orchestration (1 mesure) 1,9 %

Matrice de priorisation des mesures

RANG	ID	MESURE	CATÉGORIE	VULNÉRABILITÉS CONCERNÉES	PRIORITÉ	DIFFICULTÉ
1	**MIT-EXPLOIT-001**	Établir une veille sur les exploits publiés pour les technologies utilisées	Vulnérabilités Techniques	14	HAUTE	MOYEN
2	**MIT-VULN-001**	Établir une procédure de déploiement de correctifs en urgence	Vulnérabilités Techniques	24	CRITIQUE	MOYEN
3	**MIT-ANON-002**	Définir une matrice d'autorisation claire par rôle et service	Authentification & Accès	11	CRITIQUE	MOYEN
4	**MIT-ANON-001**	Réaliser un audit trimestriel des droits d'accès et comptes de service	Authentification & Accès	11	HAUTE	FAIBLE
5	**MIT-DATA-001**	Établir une procédure de notification de violation de données	Accès & Compromission	4	CRITIQUE	ÉLEVÉ
6	**MIT-ESCAL-001**	Établir une procédure d'approbation pour les changements de privilèges	Accès & Compromission	3	CRITIQUE	MOYEN
7	**MIT-APP-003**	Établir une procédure de remontée et correction des vulnérabilités applicatives	Vulnérabilités Techniques	—	HAUTE	MOYEN

RANG	ID	MESURE	CATÉGORIE	VULNÉRABILITÉS CONCERNÉES	PRIORITÉ	DIFFICULTÉ
8	**MIT-APP-002**	Mettre en place des revues de code sécurisé obligatoires	Vulnérabilités Techniques	—	HAUTE	MOYEN
9	**MIT-COMP-001**	Établir un plan de continuité en cas de compromission majeure	Accès & Compromission	5	CRITIQUE	ÉLEVÉ
10	**MIT-APP-001**	Former les équipes de développement aux vulnérabilités OWASP Top 10	Vulnérabilités Techniques	—	CRITIQUE	ÉLEVÉ

Focus sur les mesures prioritaires

Établir une veille sur les exploits publiés pour les technologies utilisées MIT-EXPLOIT-001

14 vulnérabilités concernées par cette mesure.

Mesure complémentaire : Mettre en place des mécanismes de protection de l'exécution (DEP, ASLR, sandboxing)

Priorité : HAUTE • Difficulté : MOYEN • Type : **Préventif**

Établir une procédure de déploiement de correctifs en urgence MIT-VULN-001

24 vulnérabilités concernées par cette mesure.

Mesure complémentaire : Mettre en place un système de gestion des correctifs automatisé et centralisé

Priorité : CRITIQUE • Difficulté : MOYEN • Type : **Préventif**

Définir une matrice d'autorisation claire par rôle et service MIT-ANON-002

11 vulnérabilités concernées par cette mesure.

Mesure complémentaire : Mettre en place une authentification obligatoire sur tous les services exposés

Priorité : CRITIQUE • Difficulté : MOYEN • Type : **Préventif**

Réaliser un audit trimestriel des droits d'accès et comptes de service MIT-ANON-001

11 vulnérabilités concernées par cette mesure.

Mesure complémentaire : Désactiver tous les accès anonymes non nécessaires sur les services

Priorité : HAUTE • Difficulté : FAIBLE • Type : **Préventif**

Exposia

Votre exposition évolue chaque jour.
Votre visibilité aussi devrait.